เอกสารประกอบการปฏิบัติการ
รายวิชา CP423324 Database and Web Security
Lab 4: PHP กับฐานข้อมูล MySQL

วัตถุประสงค์

1. เพื่อให้นักศึกษาสามารถออกแบบตารางฐานข้อมูล MySQL เบื้องต้นได้
2. เพื่อให้นักศึกษาสามารถเชื่อมต่อฐานข้อมูล MySQL ด้วย PHP ได้
3. เพื่อให้นักศึกษาสามารถบันทึกข้อมูลจาก Form ลงฐานข้อมูลด้วยคำสั่ง INSERT ได้
4. เพื่อให้นักศึกษาสามารถแสดงรายการข้อมูลจากฐานข้อมูลด้วยคำสั่ง SELECT ได้
5. เพื่อให้นักศึกษาสามารถใช้ Prepared Statement เพื่อลดความเสี่ยงจาก SQL Injection เบื้องต้นได้

คำชี้แจง

1. ให้นักศึกษา Capture ผลลัพท์ตามที่งานของแต่ละข้อกำหนดลงใน Word และบันทึกไฟล์เป็น PDF โดยให้ตั้งชื่อว่า Lab04_รหัสนักศึกษา(มีขีด).pdf
2. เมื่อทำเสร็จเรียบร้อยแล้วให้แจ้งผู้ช่วยสอน (TA) เพื่อขอรับการตรวจและตอบคำถาม (กรุณาตรวจกับพี่ TA โดยคะแนนจะมาจากการตรวจในห้องเรียน)
3. เมื่อตรวจกับ TA เรียบร้อยแล้วให้นักศึกษาส่งใน Classroom เพื่อเป็นการสำรองข้อมูล
4. ไม่อนุญาตให้ส่งงานย้อนหลังได้ ยกเว้นกรณีลาป่วย หรืออุบัติเหตุ (ต้องมีใบรับรองแพทย์)

★★★★★★★★★★

โจทย์ที่กำหนด

งานของปฏิบัติการนี้ เป็นการสร้างเว็บแอปพลิเคชันของระบบสำหรับบันทึกคำขอรับคำปรึกษาด้านการเรียน (Academic Advising Request System) โดยมีความสามารถเบื้องต้น 2 ส่วน คือ Create: เพิ่มข้อมูลคำขอรับคำปรึกษาจาก Form และ Read: แสดงรายการคำขอรับคำปรึกษาทั้งหมดจากฐานข้อมูล
โดยมีขั้นตอน ดังนี้

1.แก้ไข docker ที่เคยสร้างไว้

1.1 ให้คัดลอก ไฟล์ docker-compose.yml ใหม่ วางทับไฟล์เดิมที่เก็บไว้ที่ C:\dbwebsec-lab

1.2 จากนั้น ไปที่ CMD แล้วพิมพ์คำสั่ง

```
cd C:\dbwebsec-lab   หรือ Path ที่เก็บไฟล์ docker-compose.yml
```

1.3 จากนั้นแก้ไข docker โดยพิมพ์คำสั่ง

```
docker compose up -d
```

1.4 ให้ติดตั้ง mysqli ใน Container ปัจจุบัน พิมพ์คำสั่ง

```
docker exec -it php_apache bash
```

1.5 จากนั้นรันภายใน Container ด้วยคำสั่ง

```
docker-php-ext-install mysqli pdo_mysql
```

1.6 เมื่อติดตั้งเสร็จ ให้ออกจาก Container ด้วยคำสั่ง

```
exit
```

1.7 จากนั้นให้ Restart ด้วยคำสั่ง

docker restart php_apache

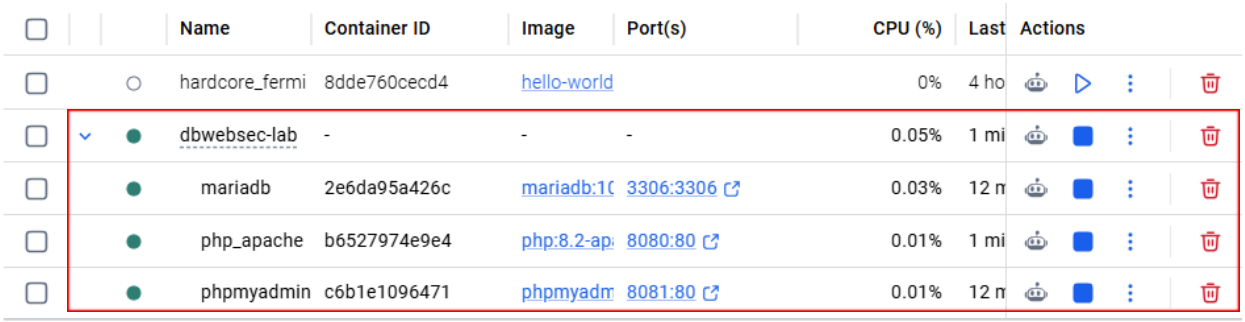
ให้ ตรวจสอบ mysqli ด้วยคำสั่ง

docker exec -it php_apache php -m | findstr mysqli

ถ้าติดตั้งสำเร็จ จะขึ้นข้อความ mysqli

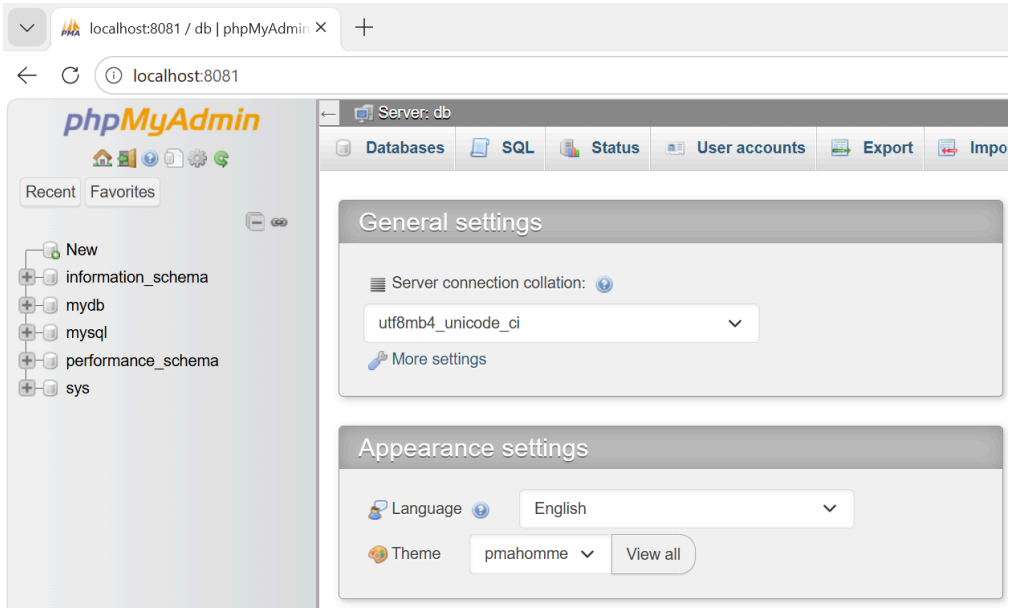
หมายเหตุ: การติดตั้ง mysqli ด้วยวิธีนี้มีผลกับ Container ปัจจุบัน หากลบหรือสร้าง Container ใหม่ อาจต้องติดตั้งซ้ำ และไม่ควรใช้ docker compose down -v เพราะจะลบ Volume ฐานข้อมูล

1.8 เปิด docker ที่เคยสร้างไว้ ให้ Start container name: dbwebsec-lab, mriadb, php_apache และ phpmyadmin

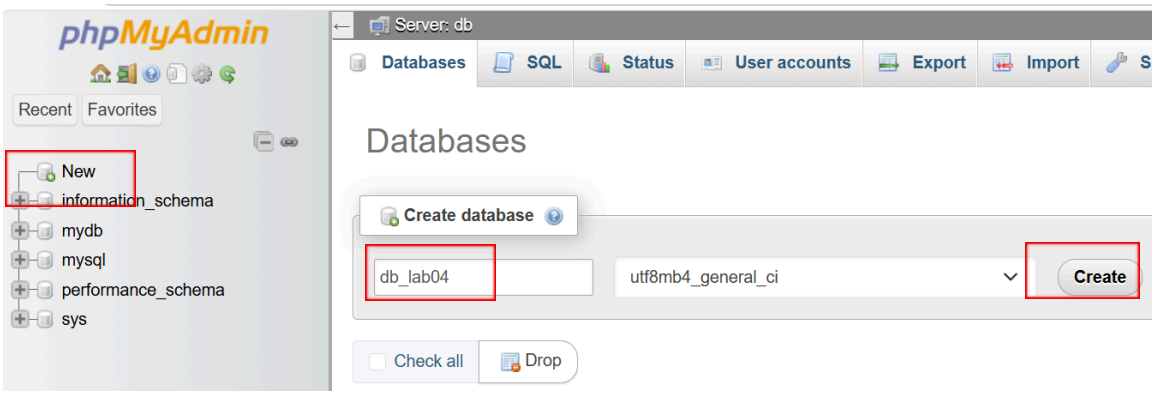


2. ให้นักศึกษาสร้าง Database และ Table

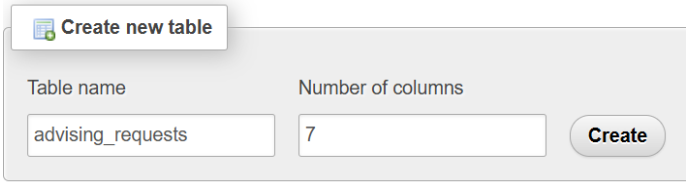
2.1 โดยให้เข้า phpMyAdmin ไปที่ Browser แล้วพิมพ์ URL: http://localhost:8081/



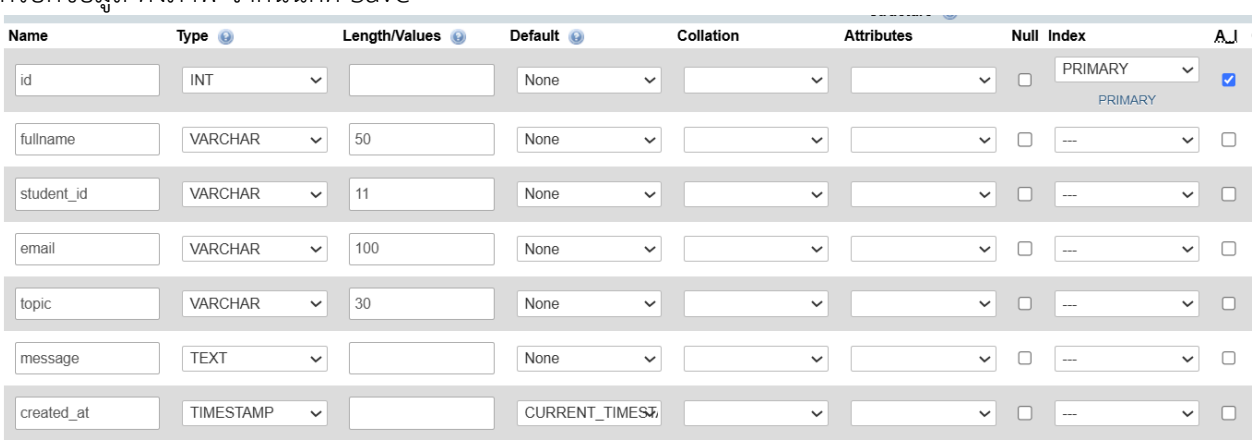
2.2 แล้วสร้างฐานข้อมูลชื่อ db_lab04 โดยคลิกที่ New แล้วพิมพ์ชื่อ ฐานข้อมูล แล้วคลิกปุ่ม Create



2.3 แล้วสร้าง ตาราง ชื่อ advising_requests โดยมีจำนวน 7 columns แล้วคลิกปุ่ม Create



กรอกข้อมูล ดังภาพ จากนั้นกด Save



คำอธิบายตาราง

Field	Data Type	ความหมาย
id	INT AUTO_INCREMENT	รหัสรายการ เพิ่มอัตโนมัติ
fullname	VARCHAR(50)	ชื่อ-นามสกุล
student_id	VARCHAR(20)	รหัสนักศึกษา
email	VARCHAR(100)	อีเมล
topic	VARCHAR(30)	หัวข้อคำปรึกษา
message	TEXT	รายละเอียดคำขอ
created_at	TIMESTAMP	วันและเวลาที่บันทึกข้อมูล

ให้นักศึกษาเพิ่มข้อมูลอย่างน้อย 1 รายการ เช่น

Student ID	Full Name	Email	Topic	Message
673380000-1	Alice Green	alice@kkumail.com	project	I would like to ask about project proposal.

3. ให้นักศึกษาสร้างโฟลเดอร์ Lab04 ไว้ภายใน C:\dbwebsec-lab\www และสร้างไฟล์จำนวน 4 ไฟล์ ได้แก่ Lab04_config.php, Lab04_index.php, Lab04_create.php และ Lab04_store.php ภายในโฟลเดอร์ Lab04

1) Lab04_config.php
เก็บค่ากำหนดพื้นฐานของระบบ และฟังก์ชันที่ใช้ซ้ำ เช่น ฟังก์ชัน h() สำหรับแสดงผลข้อมูลอย่างปลอดภัย

2) Lab04_index.php
แสดงรายการข้อมูลทั้งหมดจากฐานข้อมูล

3) Lab04_create.php
แสดง Form สำหรับเพิ่มคำขอรับคำปรึกษา

4) Lab04_store.php
รับค่าจาก Form ตรวจสอบข้อมูล และบันทึกลงฐานข้อมูล

3.1 ให้สร้างไฟล์ชื่อ Lab04_config.php เพื่อเก็บค่ากำหนดของระบบและฟังก์ชันที่ใช้ซ้ำ โดยไฟล์นี้จะถูกเรียกใช้จาก Lab04_index.php, Lab04_create.php และ Lab04_store.php

```php
<?php
declare(strict_types=1);

// ปรับค่าต่อไปนี้ให้ตรงกับ Docker/XAMPP ที่สร้างไว้
const DB_HOST = 'db';
const DB_PORT = 3306;
const DB_NAME = 'db_lab04';
const DB_USER = 'root';
const DB_PASS = 'root';

mysqli_report(MYSQLI_REPORT_ERROR | MYSQLI_REPORT_STRICT);

try {
    $conn = new mysqli(DB_HOST, DB_USER, DB_PASS, DB_NAME, DB_PORT);
    $conn->set_charset('utf8mb4');
} catch (mysqli_sql_exception $e) {
    http_response_code(500);
    exit('Database connection failed. Please check Lab04_config.php');
}

```

```php
function h(?string $value): string
{
    return htmlspecialchars($value ?? '', ENT_QUOTES | ENT_SUBSTITUTE, 'UTF-8');
}

//เปลี่ยนค่าหัวข้อในฐานข้อมูลให้เป็นข้อความที่อ่านง่าย
function topicLabel(string $topic): string
{
    $labels = [
        'study_plan'   => 'Study Plan',
        'registration' => 'Course Registration',
        'project'      => 'Project',
        'other'        => 'Other',
    ];

    return $labels[$topic] ?? $topic;
}
```

3.2 ให้สร้างไฟล์ชื่อ Lab04_index.php เพื่อแสดงในรูปแบบตาราง โดยมีคอลัมน์อย่างน้อยดังนี้

Full Name, Student ID, Email, Topic, Message, Created At

```php
<?php
declare(strict_types=1);
require_once 'Lab04_config.php';

$sql = 'SELECT fullname, student_id, email, topic, message, created_at
        FROM advising_requests
        ORDER BY created_at DESC';
$result = $conn->query($sql);

if (!$result) {
    exit('Unable to retrieve data: ' . $conn->error);
}
?>
```

```
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>Academic Advising Requests</title>
    <style>
        * { box-sizing: border-box; }
        body {
            margin: 0;
            font-family: Arial, sans-serif;
            background: #f3f6f9;
            color: #1f2937;
        }
        .container {
            width: min(1180px, 94%);
            margin: 40px auto;
        }
        .header {
            display: flex;
            justify-content: space-between;
            align-items: center;
            gap: 16px;
            margin-bottom: 20px;
        }
        h1 { margin: 0; font-size: 28px; }
```

```
        h1 { margin: 0; font-size: 28px; }
        .subtitle { margin-top: 6px; color: #6b7280; }
        .btn {
            display: inline-block;
            padding: 11px 18px;
            border-radius: 8px;
            background: #198754;
            color: #fff;
            text-decoration: none;
            font-weight: 600;
        }
        .btn:hover { background: #146c43; }
        .card {
            overflow-x: auto;
            background: #fff;
            border-radius: 12px;
            box-shadow: 0 4px 18px rgba(0, 0, 0, 0.07);
        }
        table {
            width: 100%;
            border-collapse: collapse;
            min-width: 1050px;
        }
```

```
        th, td {
            padding: 13px 14px;
            border-bottom: 1px solid #e5e7eb;
            text-align: left;
            vertical-align: top;
        }
        th {
            background: #198754;
            color: #fff;
            white-space: nowrap;
        }
        tbody tr:hover { background: #f8fafc; }
        .message { min-width: 240px; white-space: pre-wrap; }
        .empty {
            padding: 32px;
            text-align: center;
            color: #6b7280;
        }
        @media (max-width: 700px) {
            .header { align-items: flex-start; flex-direction: column; }
        }
    </style>
</head>
<body>
<div class="container">
    <div class="header">
        <div>
            <h1>Academic Advising Requests</h1>
        </div>
        <a class="btn" href="Lab04_create.php">+ Add New Request</a>
    </div>

    <div class="card">
        <?php if ($result->num_rows > 0): ?>
            <table>
                <thead>
                <tr>
                    <th>Full Name</th>
                    <th>Student ID</th>
                    <th>Email</th>
                    <th>Topic</th>
                    <th>Message</th>
                    <th>Created At</th>
                </tr>
                </thead>
```

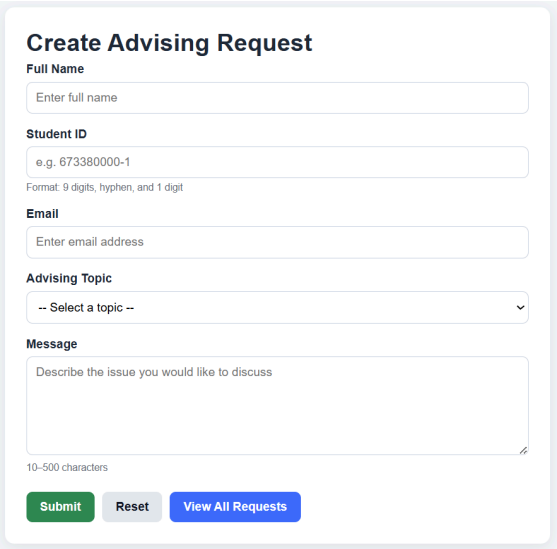
```
107                 <tbody>
108                 <?php while ($row = $result->fetch_assoc()): ?>
109                     <tr>
110                         <td><?= h($row['fullname']) ?></td>
111                         <td><?= h($row['student_id']) ?></td>
112                         <td><?= h($row['email']) ?></td>
113                         <td><?= h(topicLabel($row['topic'])) ?></td>
114                         <td class="message"><?= h($row['message']) ?></td>
115                         <td><?= h($row['created_at']) ?></td>
116                     </tr>
117                 <?php endwhile; ?>
118                 </tbody>
119             </table>
120         <?php else: ?>
121             <div class="empty">No advising requests found.</div>
122         <?php endif; ?>
123     </div>
124 </div>
125 </body>
126 </html>
```

3.3 ให้สร้างไฟล์ชื่อ Lab04_create.php เพื่อแสดง Form สำหรับกรอกคำขอรับคำปรึกษา โดยส่งข้อมูลไปยัง Lab04_store.php ด้วย method="post" และตกแต่งด้วย CSS ให้สวยงาม

กำหนดให้ Lab04_create.php มีหน้าจอสำหรับกรอกข้อมูลดังนี้

รายการ	input type	name	ข้อกำหนด	รายละเอียด / value
Full Name	text	fullname	ต้องกรอกข้อมูล และจำกัดความยาวไม่เกิน 50 ตัวอักษร	กรอกชื่อ-นามสกุล
Student ID	text	student_id	ต้องกรอกข้อมูล และมีรูปแบบ เช่น 673380000-1	กรอกรหัสนักศึกษา
Email	email	email	ต้องกรอกข้อมูล และตรวจสอบรูปแบบอีเมล	กรอกอีเมล
Advising Topic	select	topic	ต้องเลือกหัวข้อคำปรึกษา	study_plan, registration, project, other
Message	textarea	message	ต้องกรอกข้อมูล ความยาวอย่างน้อย 10 ตัวอักษร และไม่เกิน 500 ตัวอักษร	รายละเอียดที่ต้องการปรึกษา
ปุ่ม Submit	submit	-	-	ส่งข้อมูล
ปุ่ม Reset	reset	-	-	ล้างข้อมูลในฟอร์ม

ตัวอย่างหน้าจอ



3.3 ให้สร้างไฟล์ชื่อ Lab04_store.php เพื่อตรวจสอบข้อมูลที่ได้รับจาก Form และหากข้อมูลถูกต้องจะบันทึกข้อมูลลงฐานข้อมูล

```php
<?php
declare(strict_types=1);
require_once 'Lab04_config.php';

if ($_SERVER['REQUEST_METHOD'] !== 'POST') {
    header('Location: Lab04_create.php');
    exit;
}

$fullname = trim($_POST['fullname'] ?? '');
$studentId = trim($_POST['student_id'] ?? '');
$email = trim($_POST['email'] ?? '');
$topic = trim($_POST['topic'] ?? '');
$message = trim($_POST['message'] ?? '');

$errors = [];

$allowedTopics = [
    'study_plan',
    'registration',
    'project',
    'other'
];

```

```php
if ($fullname === '') {
    $errors[] = 'Full Name is required.';
} elseif (mb_strlen($fullname) > 50) {
    $errors[] = 'Full Name must not exceed 50 characters.';
}

if ($studentId === '') {
    $errors[] = 'Student ID is required.';
} elseif (!preg_match('/^[0-9]{9}-[0-9]$/', $studentId)) {
    $errors[] = 'Student ID must be in the format 673380000-1.';
}

if ($email === '') {
    $errors[] = 'Email is required.';
} elseif (!filter_var($email, FILTER_VALIDATE_EMAIL)) {
    $errors[] = 'Email format is invalid.';
} elseif (mb_strlen($email) > 100) {
    $errors[] = 'Email must not exceed 100 characters.';
}

if (!in_array($topic, $allowedTopics, true)) {
    $errors[] = 'Please select a valid advising topic.';
}

$messageLength = mb_strlen($message);

if ($message === '') {
    $errors[] = 'Message is required.';
} elseif ($messageLength < 10) {
    $errors[] = 'Message must contain at least 10 characters.';
} elseif ($messageLength > 500) {
    $errors[] = 'Message must not exceed 500 characters.';
}

```

```php
if (!empty($errors)) {
    ?>
    <!DOCTYPE html>
    <html lang="en">
    <head>
        <meta charset="UTF-8">
        <meta name="viewport" content="width=device-width, initial-scale=1.0">
        <title>Validation Error</title>
        <style>
            body {
                margin: 0;
                font-family: Arial, sans-serif;
                background-color: #f3f6f9;
                color: #1f2937;
            }
            .container {
                width: 92%;
                max-width: 650px;
                margin: 50px auto;
            }
            .error-box {
                padding: 25px;
                border: 1px solid #f5c2c7;
                border-radius: 10px;
                background-color: #f8d7da;
                color: #842029;
            }
            h1 {
                margin-top: 0;
            }
            li {
                margin-bottom: 8px;
            }
            .back-link {
                display: inline-block;
                margin-top: 15px;
                padding: 10px 18px;
                border-radius: 8px;
                background-color: #0d6efd;
                color: white;
                text-decoration: none;
                font-weight: bold;
            }
        </style>
    </head>

```

```
105     <body>
106     <div class="container">
107         <div class="error-box">
108             <h1>Unable to submit the form</h1>
109             <p>Please correct the following errors:</p>
110             <ul>
111                 <?php foreach ($errors as $error): ?>
112                     <li><?= h($error) ?></li>
113                 <?php endforeach; ?>
114             </ul>
115             <a class="back-link" href="Lab04_create.php">
116                 Back to Form
117             </a>
118         </div>
119     </div>
120     </body>
121     </html>
122     <?php
123
124     exit;
125 }
126
127 $sql = 'INSERT INTO advising_requests
128         (fullname, student_id, email, topic, message)
129         VALUES (?, ?, ?, ?, ?)';
130
131 $stmt = $conn->prepare($sql);
132 if (!$stmt) {
133     exit('Prepare failed: ' . $conn->error);
134 }
135 $stmt->bind_param(
136     'sssss',
137     $fullname,
138     $studentId,
139     $email,
140     $topic,
141     $message
142 );
143 if ($stmt->execute()) {
144     $stmt->close();
145
146     header('Location: Lab04_index.php?status=success');
147     exit;
148 }
149 exit('Unable to save data: ' . $stmt->error);
```

งานที่ 1.1 Capture หน้าจอผลลัพธ์ที่แสดง เมื่อกรอก URL http://localhost:8080/Lab04/Lab04_index.php

งานที่ 1.2 จากนั้น เมื่อ คลิกที่ปุ่ม +Add New Request ให้ Capture หน้าจอผลลัพธ์ที่แสดง ของหน้า Create Advising Request

งานที่ 2.1 ที่หน้าจอ Create Advising Request ให้กรอกข้อมูลดังนี้

Full Name: Bob Brown

Student ID: 673380001-2

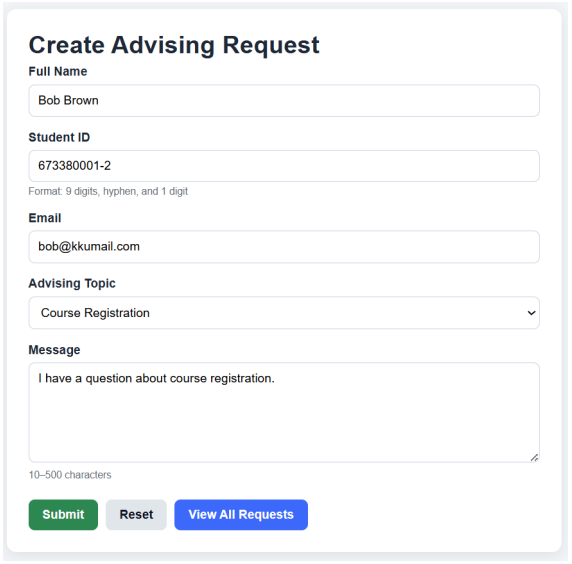
Email: bob@kkumail.com

Topic: Course Registration

Message: I have a question about course registration.

จากนั้น Capture หน้าจอผลลัพธ์ที่แสดง หลังจากกดปุ่ม Submit

ตัวอย่างหน้าจอ



งานที่ 2.2 ให้เข้าไปที่ phpMyAdmin จากนั้น Capture หน้าจอผลลัพธ์ ที่ข้อมูลถูกเพิ่มเข้าไปในฐานข้อมูล

งานที่ 3.1 ไปที่หน้าจอ Create Advising Request ให้กรอกข้อมูลดังนี้

Full Name: Alice Green

Student ID: 673380001

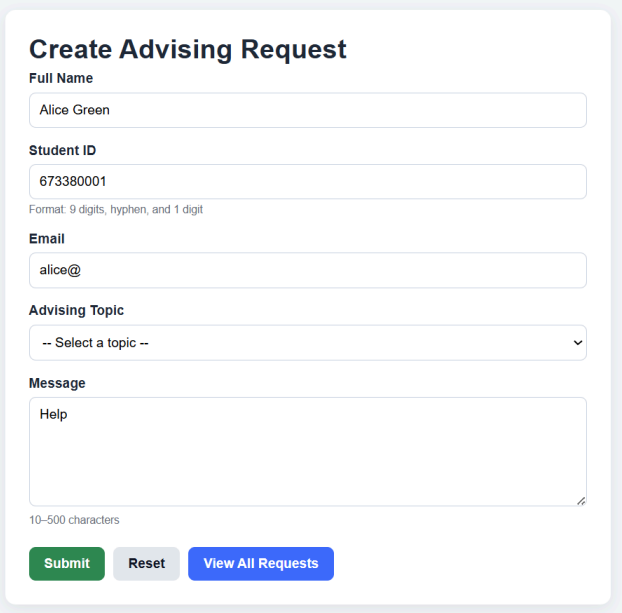
Email: alice@

Topic: ไม่เลือก

Message: Help

จากนั้น Capture หน้าจอผลลัพธ์ที่แสดง หลังจากกดปุ่ม Submit

ตัวอย่างหน้าจอ



งานที่ 3.2 ไปที่หน้าจอ Create Advising Request ให้กรอกข้อมูลดังนี้

Full Name: ช่องว่าง

Student ID: 673380000-1

Email: alice@kku.ac.th

Topic: Project

Message: Pls Help me

จากนั้น Capture หน้าจอผลลัพธ์ที่แสดง หลังจากกดปุ่ม Submit

งานที่ 3.3 ไปที่หน้าจอ Create Advising Request ให้กรอกข้อมูลดังนี้ (ทดสอบกรอกข้อมูลที่ไม่ปลอดภัย)

Full Name: <script>alert('XSS')</script>

Student ID: 673380000-1

Email: alice@kku.ac.th

Topic: Project

Message: Pls Help me

Capture หน้าจอผลลัพธ์ที่แสดง หลังจากกดปุ่ม Submit

ตัวอย่างหน้าจอ

